

HEALTH INSURANCE PORTABILITY AND ACCOUNTABILITY ACT (HIPAA)
Privacy and Security Rules - Sample Extract for Testing

=====

PART 1 - GENERAL PROVISIONS

=====

Section 160.101 - Statutory Basis

The requirements of this subpart implement sections 1171 through 1179 of the Social Security Act as added by the Health Insurance Portability and Accountability Act of 1996.

Section 160.103 - Definitions

Protected Health Information (PHI): Information that relates to the past, present, or future physical or mental health or condition of an individual, the provision of health care to an individual, or payment for health care, and that identifies the individual or could reasonably be used to identify the individual.

Covered Entity: A health plan, a health care clearinghouse, or a health care provider who transmits any health information in electronic form.

Business Associate: A person or entity that performs functions or activities on behalf of, or provides certain services to, a covered entity that involve access to protected health information.

=====

PART 2 - PRIVACY RULE (45 CFR Part 164, Subpart E)

=====

Section 164.502 - Uses and Disclosures of Protected Health Information

- (a) A covered entity may not use or disclose protected health information, except as permitted or required by this subpart.
- (b) A covered entity must comply with the applicable requirements of this subpart with respect to such information.

Section 164.506 - Uses and Disclosures to Carry Out Treatment, Payment, or Health Care Operations

- (a) A covered entity may use or disclose protected health information for its own treatment, payment, or health care operations.
- (b) A covered entity may disclose protected health information for treatment activities of another health care provider.
- (c) A covered entity may use or disclose protected health information for the payment activities of another covered entity or health care provider.

Section 164.508 - Uses and Disclosures for Which an Authorization is Required

- (a) A covered entity must obtain a valid authorization for any use or disclosure of protected health information that is not for treatment, payment, or health care operations or otherwise permitted or required by this subpart.
- (b) Authorization Required: Psychotherapy Notes - A covered entity must obtain an authorization for any use or disclosure of psychotherapy notes.
- (c) Authorization Required: Marketing - A covered entity must obtain an authorization for any use or disclosure of protected health information for marketing purposes.

Section 164.510 - Uses and Disclosures Requiring an Opportunity for the Individual to Agree or Object

(a) A covered entity may use or disclose protected health information provided that:

1. The individual is informed in advance of the use or disclosure and has the opportunity to agree to or prohibit or restrict the use or disclosure.
2. The covered entity obtains the individual's agreement, or objection.

Section 164.512 - Uses and Disclosures for Which an Authorization or Opportunity to Agree or Object is Not Required

A covered entity may use or disclose protected health information without authorization or opportunity to agree or object:

- (a) When required by law
- (b) For public health activities
- (c) About victims of abuse, neglect, or domestic violence
- (d) For health oversight activities
- (e) For judicial and administrative proceedings
- (f) For law enforcement purposes
- (g) About decedents
- (h) For cadaveric organ, eye or tissue donation purposes
- (i) For research purposes under certain conditions
- (j) To avert a serious threat to health or safety
- (k) For specialized government functions
- (l) For workers' compensation

Section 164.514 - Other Requirements Relating to Uses and Disclosures

(a) De-identification of Protected Health Information:

1. Health information is not individually identifiable if it does not identify an individual and there is no reasonable basis to believe it can be used to identify an individual.

2. De-identification may be accomplished by:

- (i) Expert determination
- (ii) Removal of 18 specified identifiers (Safe Harbor method):
 - Names
 - Geographic subdivisions smaller than state
 - Dates (except year) directly related to an individual
 - Telephone numbers
 - Fax numbers
 - Email addresses
 - Social Security numbers
 - Medical record numbers
 - Health plan beneficiary numbers

- Account numbers
- Certificate/license numbers
- Vehicle identifiers
- Device identifiers and serial numbers
- Web URLs
- IP addresses
- Biometric identifiers
- Full-face photographs
- Any other unique identifying number, characteristic, or code

(b) Minimum Necessary Requirement:

1. When using or disclosing protected health information, a covered entity must make reasonable efforts to limit the information to the minimum necessary to accomplish the intended purpose.

(c) Limited Data Set: A covered entity may use or disclose a limited data set that excludes 16 categories of direct identifiers if the covered entity enters into a data use agreement with the recipient.

Section 164.520 - Notice of Privacy Practices

(a) A covered entity must provide a notice of its privacy practices to individuals.

(b) The notice must:

1. Describe how the covered entity may use and disclose protected health information
2. Describe the individual's rights
3. Describe the covered entity's legal duties
4. Include a statement that the individual has the right to complain

Section 164.522 - Rights to Request Privacy Protection

(a) Right to Request Restriction: An individual has the right to request that a covered entity restrict uses or disclosures of protected health information.

(b) Right to Request Confidential Communications: An individual has the right to request that a covered entity communicate with the individual about protected health information by alternative means or at alternative locations.

Section 164.524 - Right of Access

(a) An individual has a right of access to inspect and obtain a copy of protected health information about the individual in a designated record set for as long as the information is maintained.

(b) The covered entity must provide the access requested within 30 days, with one 30-day extension if necessary.

Section 164.526 - Right to Amend

(a) An individual has the right to have a covered entity amend protected health information or a record about the individual in a designated record set for as long as the information is maintained.

Section 164.528 - Right to an Accounting of Disclosures

(ii) Workforce Clearance Procedure (Addressable) - Implement procedures to determine that the access of a workforce member to ePHI is appropriate.

(iii) Termination Procedures (Addressable) - Implement procedures for terminating access to ePHI when employment ends.

(a)(4) Information Access Management:

(i) Access Authorization (Addressable) - Implement policies and procedures for granting access to ePHI.

(ii) Access Establishment and Modification (Addressable) - Implement policies and procedures that establish, document, review, and modify a user's right of access.

(a)(5) Security Awareness and Training:

(i) Security Reminders (Addressable) - Periodic security updates

(ii) Protection from Malicious Software (Addressable) - Procedures for guarding against malicious software

(iii) Log-in Monitoring (Addressable) - Procedures for monitoring log-in attempts

(iv) Password Management (Addressable) - Procedures for creating, changing, and safeguarding passwords

(a)(6) Security Incident Procedures (Required):

Identify and respond to suspected or known security incidents; mitigate harmful effects; document incidents and their outcomes.

(a)(7) Contingency Plan:

(i) Data Backup Plan (Required) - Establish and implement procedures to create and maintain retrievable exact copies of ePHI.

(ii) Disaster Recovery Plan (Required) - Establish procedures to restore any loss of data.

(iii) Emergency Mode Operation Plan (Required) - Establish procedures to enable continuation of critical business processes while operating in emergency mode.

(a)(8) Evaluation (Required):

Perform a periodic technical and nontechnical evaluation in response to environmental or operational changes affecting the security of ePHI.

Section 164.310 - Physical Safeguards

(a)(1) Facility Access Controls:

(i) Contingency Operations (Addressable) - Establish procedures to allow facility access for data restoration under disaster recovery.

(ii) Facility Security Plan (Addressable) - Implement policies to safeguard the facility and equipment from unauthorized physical access.

(iii) Access Control and Validation Procedures (Addressable) - Implement procedures to control and validate a person's access.

(iv) Maintenance Records (Addressable) - Implement policies to document repairs and modifications to physical components.

(b) Workstation Use (Required):

Implement policies specifying proper functions to be performed and the manner in which those functions are to be performed.

(c) Workstation Security (Required):

Implement physical safeguards for all workstations that access ePHI to restrict access to authorized users.

(d) Device and Media Controls:

(i) Disposal (Required) - Implement policies for final disposition of ePHI and hardware/electronic media.

(ii) Media Re-use (Required) - Implement procedures for removal of ePHI before equipment is made available for re-use.

(iii) Accountability (Addressable) - Maintain a record of movements of hardware and electronic media.

(iv) Data Backup and Storage (Addressable) - Create a retrievable, exact copy of ePHI before movement.

Section 164.312 - Technical Safeguards

(a)(1) Access Control (Required):

(i) Unique User Identification (Required) - Assign a unique name and/or number for identifying and tracking user identity.

(ii) Emergency Access Procedure (Required) - Establish procedures for obtaining necessary ePHI during an emergency.

(iii) Automatic Logoff (Addressable) - Implement electronic procedures that terminate an electronic session after a predetermined time of inactivity.

(iv) Encryption and Decryption (Addressable) - Implement a mechanism to encrypt and decrypt ePHI.

(b) Audit Controls (Required):

Implement hardware, software, and/or procedural mechanisms that record and examine activity in information systems containing ePHI.

(c)(1) Integrity:

(i) Mechanism to Authenticate ePHI (Addressable) - Implement electronic mechanisms to corroborate that ePHI has not been altered or destroyed in an unauthorized manner.

(d) Person or Entity Authentication (Required):

Implement procedures to verify that a person or entity seeking access to ePHI is the one claimed.

(e)(1) Transmission Security:

(i) Integrity Controls (Addressable) - Implement security measures to ensure that ePHI is not improperly modified without detection.

(ii) Encryption (Addressable) - Implement a mechanism to encrypt ePHI whenever deemed appropriate.

Section 164.316 - Policies and Procedures and Documentation Requirements

(a) Policies and procedures (Required): Implement reasonable and appropriate policies and procedures to comply with the standards.

(b) Documentation:

(i) Time limit (Required) - Retain documentation for 6 years from the date of its creation or the date when it last was in effect.

(ii) Availability (Required) - Make documentation available to those responsible for implementing the procedures.

(iii) Updates (Required) - Review and update documentation periodically and as needed in response to environmental or operational changes.

=====

PART 4 - BREACH NOTIFICATION RULE

=====

Section 164.402 - Definitions

Breach: The acquisition, access, use, or disclosure of protected health information in a manner not permitted which compromises the security or privacy of the PHI.

Section 164.404 - Notification to Individuals

- (a) A covered entity shall notify each individual whose PHI has been breached.
- (b) The notification shall be provided without unreasonable delay and in no case later than 60 days after discovery of a breach.
- (c) The notification must include:
 - 1. A brief description of the breach
 - 2. A description of the types of information involved
 - 3. Steps individuals should take to protect themselves
 - 4. What the entity is doing to investigate, mitigate, and prevent future occurrences
 - 5. Contact procedures for individuals to ask questions

Section 164.406 - Notification to the Secretary

A covered entity shall notify the Secretary of breaches of unsecured PHI:

- (a) If a breach involves 500 or more individuals, notification must be provided contemporaneously with notice to affected individuals.
- (b) If a breach involves fewer than 500 individuals, notification must be provided no later than 60 days after the end of the calendar year.

Section 164.408 - Notification to the Media

For breaches involving more than 500 residents of a State or jurisdiction, a covered entity shall notify prominent media outlets serving the State or jurisdiction.

=====

PENALTIES FOR NON-COMPLIANCE

=====

Civil Penalties:

- Tier 1: \$100-\$50,000 per violation (unknowing violation)
- Tier 2: \$1,000-\$50,000 per violation (reasonable cause)
- Tier 3: \$10,000-\$50,000 per violation (willful neglect, corrected)
- Tier 4: \$50,000 per violation (willful neglect, not corrected)
- Annual maximum: \$1,500,000 for identical violations

Criminal Penalties:

- Up to \$50,000 and 1 year in prison (obtaining PHI under false pretenses)
- Up to \$100,000 and 5 years in prison (obtaining PHI under false pretenses with intent to sell)
- Up to \$250,000 and 10 years in prison (obtaining PHI with intent to use for commercial advantage, personal gain, or malicious harm)

=====

END OF SAMPLE EXTRACT

=====